

PRIOR ASSESSMENT REPORT

Fraud Maturity Assessment (FCMA)

Bradesco — H1 2026 cycle

Completed assessment prepared for reverse-engineering import

ILLUSTRATIVE DEMO DOCUMENT. Hypothetical scenario created to demonstrate importing an already completed assessment. The ratings are fictional inputs for a product demonstration, not statements of fact about the institution.

1. Purpose and method

This report records the outcome of the previous fraud-prevention maturity assessment. Each component was rated on a five-level scale: 1 Non-existent, 2 Informal, 3 Defined, 4 Managed, 5 Optimized. The pillar score is the mean of its component ratings and the global score is the mean of the pillar scores.

2. Summary of results

Global maturity score: **3.49** out of 5.00 across 9 pillars and 175 components.

Pillar	Name	Components	Score
P0	Fraud Strategy	9	4.11
P1	Governance, Culture, and Organizational Framework	26	3.73
P2	Fraud Risk Assessment and Threat Intelligence	17	3.24
P3	Prevention and Control Activities (Journey-Based)	28	4.18
P4	Detection, Monitoring, and Decisioning	23	4.13
P5	Investigation, Response, and Recovery	19	3.26
P6	Data, Analytics, and Technology	22	3.05
P7	Performance Management, Reporting, and Continuous Improvement	17	3.12
P8	Cross-Functional Integration and Intelligence	14	2.57

3. Context observed in the previous cycle

The bank has a documented fraud strategy approved by the Board, with a three-year time horizon that is reviewed annually. It articulates measurable strategic objectives: reduce the fraud loss rate in basis points, lower false positive friction for customers and strengthen protection of instant payments. Strategic risk decisions are explicit: management formally accepts residual fraud risk in low-value digital products, the security versus friction trade-off is documented per channel, and investment prioritization criteria rank initiatives by expected loss avoided, customer impact and cost. The fraud strategy is linked to the business strategy. The fraud function participates in product launch decisions with authority to delay high-risk launches, and digital growth plans, including new PIX and open finance features, include a fraud impact assessment before go-live. Risk acceptance is documented by product, channel and segment, approved by a committee with acceptable loss thresholds by product (for example, up to a defined number of basis points in credit cards), reviewed annually, and deviation versus thresholds is reported quarterly. A documented

trade-off analysis is measured by product and channel with actual data: false positives, blocked legitimate transactions, post-fraud NPS and control-driven abandonment, reported quarterly. The fraud opinion is mandatory for each digital product launch and has veto power or can require compensating controls before launch.

A fraud policy exists, covers all products and channels and is reviewed annually. Risk appetite is quantified by product, channel and fraud type (for example fraud loss rate in basis points) and approved by the Board, with tolerances and escalation limits by product and channel; deviations are reported monthly. The policy is aligned with enterprise risk management and operational risk. The fraud function reports to the Chief Risk Officer as a second-line unit, with defined three lines of defense roles and responsibilities. A Fraud Committee meets monthly with representatives from risk, operations, technology, legal, compliance, channels and customer service, and escalates to the Board risk committee. Cross-organizational SLAs exist between fraud and IT, operations and customer service, and escalation protocols distinguish internal fraud from external fraud. A Designated Fraud Officer holds accountability for the program. The Board receives fraud reporting quarterly with depth on losses, trends and incidents; Board members receive periodic training on fraud risk and participate in risk appetite decisions, and a C-suite executive (the Chief Risk Officer) is responsible for fraud. The code of ethics addresses fraud explicitly. An employee awareness program with annual mandatory training exists, with role-specific specialized training for branch, contact center and operations staff, a whistleblower channel that is anonymous and independent, and visible tone from the top. Anti-fraud culture is measured through an annual employee survey. Regulatory requirements are mapped (BACEN resolutions, LGPD, PIX rules), regulatory change is monitored by compliance and legal, and the history of regulatory findings is tracked with remediation plans and closure dates. The Board actively modifies risk appetite proposals: there is evidence in the minutes of changes requested versus management's original proposal. The employee awareness program is quarterly, differentiated by role, with phishing and social engineering simulations, knowledge assessments and coverage metrics. Each role has a training curriculum with target certifications (CFE, CAMS), progress is tracked and budget is allocated. Anti-fraud culture measurement includes fraud-specific survey questions and proxy indicators such as the volume of spontaneous reports and time-to-report. Regulatory change monitoring has defined sources and a quarterly bulletin with impact analysis, compliance timeline and implementation owner.

A fraud scheme inventory is maintained covering account takeover, card-not-present fraud, synthetic identity, authorized push payment scams, mule accounts, social engineering, internal fraud and third-party fraud; the inventory covers all channels and products and is updated quarterly, with an emerging threat identification process fed by investigations and intelligence. A formal documented inherent risk assessment methodology exists, performed at product and channel granularity with participation of business lines, using defined likelihood and impact rating criteria. Control effectiveness is assessed through a formal process that maps controls to fraud schemes and tests control effectiveness periodically. Residual risk is calculated for each scheme, prioritized, and residual risks are formally accepted by senior management. A dedicated fraud intelligence function integrates intelligence with detection by feeding indicators of compromise, mule accounts and new modus operandi into rules and models within days; intelligence sources are internal (investigations, chargebacks, customer complaints) and external (consortia, vendors, law enforcement, dark web monitoring), and intelligence reports are produced monthly. The inherent risk assessment is performed by product, channel and fraud type, identifying the highest-risk combinations. Design and operating effectiveness of key controls are tested semi-annually using actual data, such as known fraudulent transactions that bypassed the control, with results documented per control.

Customer journeys are mapped with vulnerability points for onboarding, login, payments, card use and servicing, with control coverage defined by journey stage. Controls are embedded by design in new journeys rather than added later as bolt-on controls, and a gap analysis compares digital and in-person journeys. A fraud by design guide is applied in the design of all new journeys. An identity theft prevention program exists; synthetic identity detection uses document verification, biometrics and data consistency checks; device validation and device fingerprinting run at digital onboarding; enhanced due diligence applies to high-risk customers; internal blacklists and shared blacklists from consortia are used, and sanctions list screening (OFAC and local lists) is performed at onboarding and continuously. Authentication methods are

defined by channel with biometrics and one-time passwords, risk-based adaptive authentication adjusts the step-up according to risk, account takeover protection detects new devices, SIM swap and credential stuffing, and the balance between security and friction in authentication is measured. Transaction limits are set by customer segment and channel and adjustable by the customer. Real-time payment controls for PIX include real-time scoring, beneficiary verification, velocity checks, mule account detection, behavioral analytics and an intelligent hold of less than 30 seconds for high-risk payments. Preventive business rules are documented and an exception and control override process requires authorization and is logged. Authorized push payment and scam prevention includes coercion indicator detection, proactive customer education campaigns and confirmation of payee. Internal fraud controls include segregation of duties, employee activity monitoring, dual authorization for sensitive operations and background checks for high-risk positions. For third parties, fraud due diligence is performed on vendors, contracts include fraud control clauses, and third-party originated fraud is monitored.

The transaction monitoring engine covers all channels and products. A rule inventory is documented with owner and purpose, thresholds are recalibrated quarterly using true positive and false positive data with before and after metrics for each change, rule set governance requires approval and versioning of changes, and rule performance (detection rate and precision) is measured per rule. Machine learning models are in production for card, digital banking and PIX; models are independently validated by a model risk team, champion/challenger testing runs challengers in shadow mode before a swap, production performance is monitored continuously for drift, the models use supervised and unsupervised techniques including gradient boosting and anomaly detection, model explainability is provided to analysts through reason codes, and a standardized model development process exists. Independent model validation by the second line follows SR 11-7 principles: conceptual soundness, outcomes analysis and ongoing monitoring, with a report of findings. Real-time scoring is under 200 ms for all channels and latency is monitored against an SLA. Real-time capability scores transactions in under 100 milliseconds, complemented by batch processes for retrospective patterns, with a decisioning architecture that combines rules, models and policies. Alert management uses a defined triage process with prioritization by risk score; the customer impact of false positives is measured and reduced; analyst productivity is tracked; and dispositions are categorized with feedback to rules and models. A unified customer view and cross-channel event correlation link activity across mobile, internet banking, cards and PIX. Network and graph analytics are still at pilot stage and not yet in production; mule network analysis is performed manually by investigators.

A case management tool is used with workflow by case type, and cases are assigned automatically based on type and workload. A formal documented investigation methodology exists; investigators are trained and certified; evidence is preserved under defined handling and chain-of-custody protocols; and case escalation and classification criteria are defined. A loss recovery process exists with chargebacks and recalls; losses are accounted for by type and channel with reconciliation to the general ledger; and write-off decisions require defined approval levels. Customer notification protocols define timing and channel, a re-issuance and restitution process exists for cards and accounts, and customer liability limitation policies are documented. Regulatory reporting is in place: the fraud suspicious activity reporting process refers cases to compliance with timelines, structuring patterns are referred to compliance for currency transaction reports with evidence, and payment network and BACEN reporting is performed on schedule. A post-mortem process analyzes major cases and the lessons learned feed back into detection rules and models. Dispute resolution procedures exist with defined timelines and customer communication. More than half of the investigation team holds CFE or CAMS certification, with a continuous training plan and budget. The recovery process covers chargebacks, judicial recovery and fraud insurance; the recovery rate is tracked by type and channel, analyzed monthly by a dedicated recovery team. Re-issuance and restitution have documented SLAs (card re-issuance within 48 hours, provisional credit within 24 hours) that are measured and reported, differentiated by customer segment, with post-restitution customer satisfaction measured.

Input data quality is monitored with automated checks, data lineage is documented for fraud data feeds, fraud data governance assigns data owners, and data quality remediation processes track issues to closure. Input data quality is measured on completeness, accuracy and timeliness with a quality dashboard and alert thresholds.

Data quality incidents follow a documented process of issue identification, root cause, remediation and validation, are classified by severity, have remediation SLAs and are escalated if not resolved on time. A dedicated fraud data repository exists, with data enrichment from device, geolocation and external sources, cross-channel and cross-system integration, and both real-time and batch data availability. The ML model lifecycle includes a model inventory, model risk tiering, a standardized development process, continuous monitoring of production models, and a process for model retirement and replacement. The technology stack has a tool inventory; vendor concentration risk is assessed; technology vendor contracts and SLAs are managed with periodic reviews. Infrastructure has scalability capacity for peak volumes, high availability and disaster recovery with tested failover, and production performance monitoring of latency and throughput. A new technology evaluation process exists, PCI compliance and encryption of card data are in place, and technology trends are tracked. A documented new technology evaluation process covers identification, fit evaluation with proof of concept and business case, and a fraud lab with anonymized real data runs proofs of concept every year.

A defined set of KRIs and KPIs exists, with risk translated into monetary terms. Fraud operational KPIs (alert volumes, time to disposition, analyst productivity), fraud financial KPIs (loss rate in basis points, recoveries, cost of fraud), customer and experience KPIs (false positive rate, customer friction, complaints) and cross-functional KPIs shared with IT and operations are reported. Reporting to management is monthly and to the Board quarterly, with standardized content and quality review, and significant incidents are reported immediately. Internal audit includes fraud in its annual plan; external audits or independent reviews of the fraud program are performed periodically; findings are tracked and remediation monitored to closure. Benchmarking is performed against a peer group, against the bank's own trend over time (internal benchmark), and through participation in industry surveys and data exchanges. A multi-year program roadmap exists with change management and communication of the evolution of the fraud program.

Fraud and cybersecurity operate under a coordinated operating model with fraud-cyber intelligence sharing, shared use cases (account takeover, phishing, malware) and joint operations through a fusion cell. Fraud and AML coordinate by sharing alerts and data, sharing typologies, and holding a joint financial crime committee. Fraud works with legal and compliance under a legal framework for fraud action (account blocking, recoveries), and compliance reviews the fraud program. Fraud-IT alignment includes fraud by design in product development, IT SLAs for fraud engine support, and fraud participation in new technology evaluation. The bank participates in consortia and information sharing groups (such as FS-ISAC and local banking associations), maintains a relationship with law enforcement, and actively contributes intelligence rather than only consuming it. A fraud by design checklist is a mandatory gate in each sprint and release.

Annex A. Component ratings

ID	Component	Level	Label	Reference descriptor
0.1.1	Existence of a documented strategy	2	Informal	An informal document or internal presentation mentions fraud objectives, but it is not approved by senior...
0.1.2	Articulation of strategic objectives	5	Optimized	Objectives are decomposed by product, channel, and segment. A balanced scorecard is used that includes...
0.1.3	Strategy time horizon	5	Optimized	A – year plan exists with scenarios (base, optimistic, adverse), linked to the bank's strategic plan. It...
0.2.1	Explicit risk acceptance	5	Optimized	Risk acceptance is dynamically calibrated using actual loss data, industry benchmarks, and cost-benefit...
0.2.2	Documented security vs. friction trade-off	4	Managed	The trade-off is measured by product/channel with actual data: false positives, blocked legitimate...
0.2.3	Investment prioritization criteria	4	Managed	A ROI-based prioritization model is used: for each initiative, estimated avoided loss, implementation...
0.3.1	Fraud–business strategy linkage	4	Managed	Each launch requires a fraud risk assessment approved before go-live. Fraud has a formal seat on the...
0.3.2	Participation in launch decisions	4	Managed	The fraud opinion is mandatory and has veto power or can require compensating controls before launch.
0.3.3	Fraud consideration in digital growth	4	Managed	Each digital initiative has a fraud risk profile with differentiated controls, success metrics, and a...
1.1.1	Policy existence and scope	4	Managed	The policy includes definitions, scope, roles, quantified risk appetite, tolerances by product/channel,...
1.1.2	Quantified risk appetite	4	Managed	Risk appetite is quantified by product, channel, and fraud type. It includes tolerances, escalation...
1.1.3	Tolerances and limits by product/channel	4	Managed	Each product/channel has specific documented tolerances, with early warning and escalation thresholds....
1.1.4	Policy review process	5	Optimized	The review includes multi-jurisdictional regulatory benchmarking, gap analysis vs. standards (COSO/ACFE,...
1.1.5	Alignment with ERM and operational risk	1	Non-existent	The fraud policy makes no reference to Enterprise Risk Management or operational risk.
1.2.1	Position in the organizational chart	4	Managed	Reports to the CRO or equivalent with direct Board access. The Head of Fraud participates in executive...
1.2.2	3LoD roles and responsibilities	3	Defined	A RACI document exists that maps fraud roles to LoD, LoD, and LoD.
1.2.3	Fraud Committee	3	Defined	Committee with an approved charter, minimum monthly frequency, formal minutes, and attendance from fraud,...
1.2.4	Committee composition	4	Managed	Includes fraud, compliance/AML, cyber/IT, legal, operations, lines of business, and an audit observer....
1.2.5	Board escalation mechanism	4	Managed	In addition to thresholds, the Board receives quarterly reports with trends, benchmarks, KPIs, and...

1.2.6	Cross-organizational SLAs	3	Defined	Documented SLAs for at least key relationships (fraud-IT, fraud-ops).
1.2.7	Escalation protocols (internal vs. external fraud)	3	Defined	Documented differentiated protocols: external fraud through monitoring; internal fraud is escalated to...
1.2.8	Designated Fraud Officer	4	Managed	The Officer has documented authority, a dedicated budget, and direct Board access.
1.3.1	Frequency and depth of Board reporting	4	Managed	The report includes peer benchmarks, root cause analysis, remediation status, and loss projections.
1.3.2	Board understanding of fraud risk	5	Optimized	Continuous education program (+ sessions/year), has visited the monitoring center, and its questions have...
1.3.3	Participation in risk appetite decisions	4	Managed	The Board actively modifies proposals: there is evidence of changes requested vs. management's original...
1.3.4	Responsible C-suite executive	5	Optimized	A Chief Fraud Officer or equivalent exists with a seat on the executive committee, a dedicated budget, and...
1.4.1	Code of ethics and fraud	2	Informal	The code mentions fraud generically ('do not tolerate fraudulent conduct') without definitions, examples,...
1.4.2	Employee awareness program	4	Managed	Quarterly program with phishing/social engineering simulations, knowledge assessments, and coverage metrics.
1.4.3	Role-specific specialized training	3	Defined	Differentiated plan: analysts (typologies), investigators (chain of custody), technology (rules/models),...
1.4.4	Whistleblower channel	4	Managed	Actively promoted (semi-annual campaigns), has a response SLA (<h), case tracking, and protection against...
1.4.5	Tone from the top	4	Managed	Quarterly messages, participation in awareness events, with program data.
1.4.6	Anti-fraud culture measurement	4	Managed	In addition to the survey, proxy indicators are measured: volume of spontaneous reports, time-to-report,...
1.5.1	Regulatory requirements mapping	4	Managed	The matrix includes multi-jurisdiction coverage, compliance status, owner, and remediation plan. Presented...
1.5.2	Regulatory change monitoring	4	Managed	The bulletin includes impact analysis, compliance timeline, and implementation owner.
1.5.3	Regulatory findings history and remediation	4	Managed	Reported monthly to the committee. Aging, closure rate, and recurrence are measured. Those > days are...
2.1.1	Fraud scheme inventory	3	Defined	Documented inventory differentiated by type (internal/external), product, channel, and modus operandi. Has...
2.1.2	Emerging threat identification process	2	Informal	The team occasionally reads industry publications, but without a structured process or designated owner.
2.1.3	Inventory coverage	3	Defined	Covers at least: transactional, origination, ATO, internal fraud, and digital channel fraud.
2.1.4	Update frequency	3	Defined	Updated at least annually as part of the risk assessment.
2.2.1	Formal documented methodology	2	Informal	Informal methodology (brainstorming session) that is neither documented nor repeatable.
2.2.2	Assessment granularity	3	Defined	Performed by product and by channel.

2.2.3	Business line participation	3	Defined	Each line designates a representative who participates in the annual assessment.
2.2.4	Likelihood and impact rating criteria	3	Defined	Documented criteria exist: likelihood is measured on a defined scale (e.g., =rare, =almost certain) and...
2.3.1	Control assessment process	3	Defined	Annual assessment process for key controls with sample testing and documentation.
2.3.2	Control-to-scheme mapping	4	Managed	The matrix is updated with each new scheme. Coverage is measured. Gaps are prioritized.
2.3.3	Control effectiveness testing	3	Defined	Effectiveness tests are executed at least annually for key controls: design effectiveness is verified and...
2.4.1	Residual risk calculation	4	Managed	Quantified in USD (expected post-control loss) by product/channel. Compared vs. approved risk appetite.
2.4.2	Formal acceptance of residual risks	4	Managed	Acceptance requires the business owner's signature + risk committee approval, with documented justification.
2.5.1	Fraud intelligence function	3	Defined	Intelligence owner with defined sources and regular report production.
2.5.2	Integration of intelligence with detection	4	Managed	The process has an SLA (e.g., <h for critical threat). Time-to-deploy from intel to production is measured.
2.5.3	Intelligence sources (internal and external)	4	Managed	Internal sources (investigations, alerts, complaints) are consolidated with external ones (consortia,...
2.5.4	Intelligence report production	4	Managed	Differentiated reports are produced: operational (weekly, for analysts and rules), tactical (monthly, for...
3.1.1	Journey mapping with vulnerability points	5	Optimized	Include risk heat maps by point, actual loss data, and semi-annual war games for new vulnerabilities.
3.1.2	Control coverage by journey stage	5	Optimized	Adaptive controls: intensity adjusts dynamically based on risk score. Capture rate and friction are...
3.1.3	Embedded vs. bolt-on controls	3	Defined	The main controls are designed as part of the original journey.
3.1.4	Gap analysis of digital vs. in-person journeys	5	Optimized	A continuous penetration testing program for digital journeys exists that identifies vulnerabilities...
3.2.1	Identity theft prevention program	4	Managed	Documentary + non-documentary verification + digital ID verification. Detection rate at onboarding is...
3.2.2	Synthetic identity detection	5	Optimized	Multi-layered approach: score + consortium data + graph analysis + device verification. Specific detection...
3.2.3	Device validation at digital onboarding	3	Defined	Device fingerprinting at onboarding compared against blacklists.
3.2.4	Enhanced due diligence for high-risk customers	4	Managed	EDD is applied with fraud criteria differentiated by product, channel, and profile. Criteria are reviewed...
3.2.5	Internal and shared blacklists (consortia)	4	Managed	Lists are updated in near-real-time from investigations and external sources. Used in the detection...
3.2.6	Sanctions list screening (OFAC)	5	Optimized	Real-time, multi-list screening (OFAC, UN, EU, local lists), with advanced fuzzy matching. Integrated with...
3.3.1	Authentication methods by channel	4	Managed	In addition to MFA, advanced methods in at least one channel: biometrics, device binding, behavioral...
3.3.2	Risk-based adaptive authentication	5	Optimized	The authentication engine is continuously trained with confirmed fraud data. Optimized to minimize...
3.3.3	ATO protection	4	Managed	Session risk score integrating device fingerprint, behavioral biometrics, velocity, IP reputation, SIM...

3.3.4	Security/friction balance in authentication	4	Managed	Abandonment, completion time, error rate, and NPS are measured by authentication method. Used to calibrate...
3.4.1	Transaction limits	5	Optimized	Fully adaptive limits: recalculated per transaction based on risk score, context (time, device,...
3.4.2	Real-time payment controls (PIX/instant)	4	Managed	Includes mule account detection, behavioral analytics, confirmation of payee (CoP), intelligent hold (<...
3.4.3	Preventive business rules	3	Defined	Differentiated rules exist: velocity checks, geo-fencing, merchant category restrictions, and atypical...
3.4.4	Exception and control override process	3	Defined	A documented process exists: request, justification, approval by a defined authority, and exception log.
3.5.1	Coercion indicator detection	5	Optimized	ML model specific to APP fraud integrating behavioral, transactional, and contextual data. Intelligent...
3.5.2	Proactive customer education	4	Managed	Contextual warnings within the journey (e.g., when transferring to a new beneficiary). Interaction rate is...
3.5.3	Confirmation of Payee (CoP) protocol	4	Managed	CoP is applied to all payments to new beneficiaries. Mismatch rate and its correlation with fraud are...
3.6.1	Segregation of duties	4	Managed	The matrix is systemically enforced in core system permissions. Audited semi-annually. Violations are...
3.6.2	Employee activity monitoring	4	Managed	Dedicated rule engine for internal fraud: behavior, access to sensitive information, transactions on...
3.6.3	Dual authorization for sensitive operations	5	Optimized	Dual authorization effectiveness is monitored: cases where the second approval detected anomalies are...
3.6.4	Background checks for high-risk positions	5	Optimized	A continuous monitoring program is used: automatic alerts if an employee in a high-risk position has...
3.7.1	Fraud due diligence on vendors	4	Managed	Specific questionnaire with scoring. High-risk parties require periodic review and contractual controls.
3.7.2	Contractual controls with third parties	5	Optimized	Contracts include measurable fraud KPIs (e.g., fraud rate originated by the third party <X bps), penalties...
3.7.3	Third-party originated fraud monitoring	2	Informal	It is known that some third parties originate fraud, but it is neither measured nor tracked.
4.1.1	Coverage by channels and products	5	Optimized	Universal coverage with unified scoring: channel rules + cross-channel ML model + network intelligence....
4.1.2	Rule inventory and documentation	4	Managed	Additionally: detection rate, FP rate, last calibration date, and threshold justification. Reviewed...
4.1.3	Threshold calibration	4	Managed	Quarterly recalibration with TP and FP data, documenting each change with before/after metrics.
4.1.4	Rule set governance	4	Managed	Includes a change advisory board, backtesting, impact analysis, and rollback procedure.
4.1.5	Rule performance	3	Defined	Detection rate and FP rate are measured per rule at least quarterly. Top- by volume are identified.
4.2.1	ML model existence and scope	5	Optimized	Complete portfolio: by fraud type, channel, and segment. Advanced techniques (deep learning, graph neural...
4.2.2	Independent model validation	4	Managed	Follows OCC - / SR -: conceptual soundness, outcomes analysis, ongoing monitoring. Report with findings.
4.2.3	Champion/challenger	3	Defined	At least one challenger in shadow mode to compare performance before the swap.
4.2.4	Production performance monitoring	5	Optimized	Complete framework: performance + feature drift + concept drift + data quality checks. Monthly...

4.2.5	Model types and techniques used	4	Managed	A model ensemble combining multiple techniques (supervised, unsupervised, neural networks) is used. Each...
4.2.6	Model explainability and interpretability	4	Managed	Explainability is integrated into the investigation workflow: the analyst sees the top-N reasons for each...
4.2.7	Model development process	4	Managed	The process includes peer review at each stage, data governance (training data lineage), out-of-time...
4.3.1	Real-time capability	3	Defined	Real-time scoring (<ms) for main channels.
4.3.2	Complementary batch processes	4	Managed	Batch processes cover typologies that cannot be detected in real-time: slow-burn patterns, synthetic ID...
4.3.3	Decisioning architecture	4	Managed	The architecture includes intermediate decisions: approval with step-up authentication, approval with...
4.4.1	Triage process	4	Managed	Automated triage: a priority score assigns alerts to queues with differentiated SLAs. Top-priority alerts...
4.4.2	Customer impact of false positives	5	Optimized	An impact model quantifies the total cost of friction in USD. Used to calibrate detection thresholds.
4.4.3	Analysis team productivity	2	Informal	It is informally known how many alerts each analyst reviews, but it is not measured or compared.
4.4.4	Disposition categorization and feedback	4	Managed	Dispositions directly feed rule and model performance metrics. The false positive reason is used to...
4.5.1	Unified customer view	5	Optimized	Score with cross-channel features in real-time: the model detects multi-channel patterns that no single...
4.5.2	Cross-channel event correlation	5	Optimized	The correlation engine uses event-driven architecture: each customer event is evaluated in the context of...
4.6.1	Graph analysis capability	5	Optimized	Near-real-time graph analytics as feature input for ML models. Graph neural networks for community detection.
4.6.2	Graph visualization tools	5	Optimized	Graph visualization is automatically generated for each high-risk alert: the analyst sees the customer's...
5.1.1	Case management tool	3	Defined	Dedicated tool (NICE Actimize, Verafin, or similar) with workflows by case type and specific fields.
5.1.2	Workflow by case type	2	Informal	It is informally known that an ATO is investigated differently, but without documentation.
5.1.3	Case assignment (automatic vs. manual)	3	Defined	Assignment uses at least criteria: fraud type and analyst workload. Documented.
5.2.1	Formal documented methodology	3	Defined	Documented methodology with: steps, classification criteria, report templates, evidence checklist.
5.2.2	Investigator competence	4	Managed	At least % hold CFE or CAMS. Continuous training plan with budget.
5.2.3	Evidence handling and preservation protocols	2	Informal	Evidence is kept in shared folders or emails, without a formal chain of custody.
5.2.4	Case escalation and classification criteria	2	Informal	High-amount or high-visibility cases are informally escalated, without documented criteria.
5.3.1	Recovery process	3	Defined	Process includes: chargebacks, judicial recovery, and fraud insurance. Recovery rate is tracked.
5.3.2	Loss accounting	3	Defined	Fraud-specific GL codes. Gross, recovered, and net loss are recorded. Reported monthly.
5.3.3	Write-off decisions	4	Managed	The process includes a recoverability analysis before write-off. Justification is documented. Write-off...

5.4.1	Customer notification protocols	4	Managed	Differentiated by fraud type and segment. Post-notification NPS and perceived resolution time are measured.
5.4.2	Re-issuance and restitution process	3	Defined	Documented process with SLAs: card re-issuance <h, provisional credit <h, and digital credential...
5.4.3	Customer liability limitation policies	3	Defined	A documented policy exists defining customer liability by fraud type and channel, aligned with regulation...
5.5.1	Fraud-related SAR process	4	Managed	Referral SLAs (<h for urgent), compliance feedback, and quality metrics.
5.5.2	Currency Transaction Reports (CTRs)	3	Defined	Fraud refers to compliance transactions that may require a CTR when structuring patterns are detected....
5.5.3	Payment network reporting	4	Managed	Network intelligence is actively consumed and contributed. Network data is used to calibrate rules and...
5.6.1	Post-mortem process	4	Managed	Standard template, execution within days, action items with owners and deadlines tracked at the committee.
5.6.2	Feedback to detection	4	Managed	Feedback is systemic: each closed case generates a feature record that feeds model/rule development. Lead...
5.7.1	Dispute resolution procedures	4	Managed	Procedures include SLAs by dispute type, deadline compliance tracking, and aging reports.
6.1.1	Input data quality	3	Defined	At least dimensions are measured (completeness, accuracy, timeliness) for key data. Documented.
6.1.2	Documented data lineage	3	Defined	Lineage documented for key fields: source, transformations, frequency, consumer.
6.1.3	Fraud data governance	3	Defined	Data ownership and stewardship defined for fraud datasets. Data dictionary available.
6.1.4	Data quality remediation processes	3	Defined	A documented process exists: issue identification, root cause, remediation, and validation. Quality...
6.2.1	Fraud data repository	3	Defined	Data warehouse or data lake consolidating alerts, investigations, losses, and rules. Used for reporting.
6.2.2	Data enrichment	3	Defined	+ sources: device fingerprint, geolocation, bureau, and at least one consortium source.
6.2.3	Cross-channel and cross-system integration	3	Defined	Integration with at least sources exists: core banking, digital channels, cards, and call center. Data...
6.2.4	Real-time vs. batch data availability	3	Defined	Transactional and customer profile data is available in real-time for scoring. Analytical data is batch.
6.3.1	Model inventory	4	Managed	Additionally: current performance metrics, last validation date, tiering, and next scheduled validation.
6.3.2	Model risk tiering	4	Managed	Tiering determines: validation frequency, documentation depth, approval level, monitoring frequency.
6.3.3	Standardized development process	3	Defined	Documented process with stages: problem statement, data exploration, feature engineering, model selection,...
6.3.4	Continuous production model monitoring	4	Managed	Automated monitoring with alerts: feature drift (PSI >.), performance degradation (AUC drop >X%), data...
6.3.5	Model retirement/replacement process	3	Defined	A documented retirement process exists: retirement criteria (performance degradation, obsolescence),...
6.4.1	Tool inventory	2	Informal	The main ones are known but without a formal inventory with licensing and support.
6.4.2	Vendor concentration risk	2	Informal	Dependency on the main vendor is recognized but alternatives have not been evaluated.

6.4.3	Technology vendor contract and SLA management	4	Managed	SLA compliance is measured monthly. Non-compliance is formally escalated. Negotiation is based on actual...
6.5.1	Scalability capacity	3	Defined	Load testing executed at least once. Maximum throughput is known.
6.5.2	Availability and disaster recovery	4	Managed	DR tested annually. RTO < hours. Automatic or semi-automatic failover.
6.5.3	Production performance monitoring (latency, throughput)	2	Informal	Performance is reviewed when there are complaints or slowness incidents.
6.6.1	New technology evaluation process	2	Informal	Evaluated ad-hoc when a vendor presents them.
6.6.2	PCI and encryption	3	Defined	Sensitive fraud data (PAN, tokens) is encrypted in transit and at rest in compliance with PCI DSS.
6.6.3	Technology trend tracking	3	Defined	A radar of emerging fraud technologies is maintained, updated semi-annually, with a relevance evaluation...
7.1.1	Defined metrics set	3	Defined	Documented set of at least metrics: fraud loss rate, detection rate, FP rate, time-to-detect,...
7.1.2	Translation of risk into monetary terms	2	Informal	Total loss is reported but without connection to control ROI or customer impact.
7.1.3	Fraud operational KPIs	2	Informal	Only alert and case volume is measured, without breakdown or benchmark.
7.1.4	Fraud financial KPIs	4	Managed	Program ROI is calculated: (avoided loss – program cost) / program cost. Reported to the CFO quarterly.
7.1.5	Customer and experience KPIs	4	Managed	Additionally measured: post-fraud customer effort score, total perceived resolution time, and revenue lost...
7.1.6	Cross-functional KPIs	1	Non-existent	No collaboration KPIs between fraud and other areas are measured.
7.2.1	Reporting frequency and format	4	Managed	Monthly operational reports + quarterly executive reports. Interactive dashboard, exception-based, with...
7.2.2	Report content and quality	4	Managed	Reports are exception-based: they highlight deviations vs. thresholds, include root cause analysis of...
7.2.3	Significant incident reporting	3	Defined	Documented significant incident criteria (amount >\$X, type, reputational impact) and a notification...
7.3.1	Internal audit scope	4	Managed	Annual audit covering governance, detection, investigation, reporting, and LoD. Findings are tracked.
7.3.2	External audits or independent reviews	2	Informal	Fraud has been included in the scope of a regulatory audit, but no voluntary external review has been...
7.3.3	Findings tracking and remediation	3	Defined	A centralized tracker exists with: finding, severity, owner, remediation plan, committed date, and status.
7.4.1	Peer group benchmarking	3	Defined	Participates in at least one industry survey (ACFE, Gartner, FEBRABAN) and results are compared.
7.4.2	Internal benchmark (own trend over time)	3	Defined	A history of at least years of main metrics is maintained. Trend is visualized and change drivers are...
7.4.3	Industry survey and data participation	4	Managed	Participates in multiple surveys and consumes vendor benchmarks (FICO consortium, Actimize, Visa/MC...
7.5.1	Multi-year roadmap	4	Managed	Linked to the business strategy and assessment gap analysis. Reviewed semi-annually with the committee.
7.5.2	Change management and evolution communication	3	Defined	A communication plan for major program changes exists. Impacted areas are notified in advance.

8.1.1	Current operating model	3	Defined	Intelligence sharing: cyber alerts are referred to fraud when they have a financial component, and vice...
8.1.2	Fraud-cyber intelligence sharing	2	Informal	Findings are informally shared when someone considers them relevant, without a process.
8.1.3	Shared use cases and joint operations	3	Defined	At least shared use cases have been defined (e.g., ATO, phishing → fraud, malware → credential theft) with...
8.2.1	Alert and data sharing	2	Informal	Cases are referred manually for SAR, without systematic sharing.
8.2.2	Shared typologies and data sharing	4	Managed	Automated data sharing exists: fraud alerts involving mule accounts are automatically referred to AML with...
8.2.3	Joint financial crime committee	3	Defined	A monthly joint fraud-AML meeting exists to review cross-cutting cases, share intelligence, and coordinate...
8.3.1	Legal framework for fraud action	3	Defined	Documented protocol for when to involve Legal with thresholds and steps to follow.
8.3.2	Compliance review of the fraud program	4	Managed	The compliance review includes: regulatory requirements mapping, key control testing, and recommendations....
8.4.1	Fraud by design in product development	3	Defined	Fraud participates in the requirements phase. Pre-launch assessment is documented.
8.4.2	IT SLAs for fraud engine support	3	Defined	Documented SLAs exist: rule deployment time (<h urgent, < days normal), incident support (P <h, P <h), and...
8.4.3	Fraud participation in new technology evaluation	2	Informal	Fraud is notified after a new technology is selected, without input authority.
8.5.1	Consortium participation	1	Non-existent	Does not participate in information-sharing consortia.
8.5.2	Law enforcement relationship	1	Non-existent	No formal relationship with law enforcement for fraud exists.
8.5.3	Active contribution vs. passive intelligence consumption	2	Informal	The bank shares the minimum required information (e.g., mandatory chargebacks to the network).